PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Cloisonnement système

03-430 ANSSI - Recommandations pour la mise en place de cloisonnement système — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le cloisonnement vise à réduire l'environnement d'exécution aux ressources strictement nécessaires en interdisant par défaut tout ce qui n'est pas autorisé dès la conception.
2. L'analyse de sécurité doit identifier les biens sensibles, le modèle d'attaquant, le périmètre incluant la surface d'attaque et de friction, ainsi que les fonctions de sécurité.
3. Le moniteur de référence et tout composant dont le privilège impacte l'intégrité ou la politique de sécurité sont considérés comme des composants de confiance.

Cloisonnement et moindre privilège

Notion	À retenir
Objectif/Démarche	Réduire l'environnement d'exécution aux ressources **strictement nécessaires**. Stratégie : **interdire par défaut** et n'autoriser que le nécessaire dès la conception.
Formalisation	Définir le domaine d'exécution de chaque tâche (**politique de sécurité**). La **fonction de sécurité** garantit le respect de cette politique.
Exemples	Moniteur de référence : processus → **noyau** ; utilisateurs (DAC/MAC, **SELinux**, **AppArmor**) → **noyau** ; hypervision → le **système d'hypervision** (VM = tâche) ; conteneurs/cages → noyau + **gestionnaires de cages**.

Identification des besoins en cloisonnement

Notion	À retenir
Analyse sécurité	Identifier **biens sensibles**, **modèle d'attaquant**, **périmètre** (**surface d'attaque** et **friction**) et **fonctions de sécurité**. Doit figurer dans les **documents de conception ou d'intégration**.
Usages et objectifs	Caractériser les **usages distincts** (connectivité, criticité, périodicité, cycle de vie). Objectifs : minimiser **surface d'attaque** et **friction**, cloisonner via **moniteur de référence**, limiter les **conséquences de compromission**.

Analyse de la sécurité du cloisonnement

Notion	À retenir
Moniteur et composants	Le **moniteur de référence** et tout composant avec privilège impactant l'intégrité ou la politique sont des **composants de confiance**. Ils exigent : spécifications simples, langage **fortement typé**, audit **indépendant** et tests complets.
Recommandations	Réduire au **strict minimum** (code inutilisé), utiliser **canaris de pile**, **W xor X** et **ASLR**. Le moniteur doit éviter les failles **TOCTTOU**, vérifier la complétude et l'intégrité, et limiter les options de configuration.
Évaluation et raffinement	Identifier **tâches, ressources et moniteur**, mesurer l'écart avec les recommandations et durcir. Le mécanisme ne doit pas dégrader la sécurité globale. Raffiner le cloisonnement **à l'intérieur** des grands domaines (**VM**, **conteneur**).

Pièges et confusions

⚠ Croire qu'un contrôle d'accès implémenté par un module de code au sein même du processus de l'utilisateur constitue un cloisonnement réel.

⚠ Reposer l'analyse de sécurité sur l'hypothèse que le composant entier est de confiance, y compris son noyau ou son hyperviseur.

⚠ Autoriser un composant à exiger l'abaissement du niveau de durcissement ou de cloisonnement des autres composants du système.

⚠ Confondre la surface d'attaque (interfaces vers l'attaquant) et la surface de friction (autres interfaces, notamment vers les composants de confiance).

Sigles et définitions

Tâche	Ensemble d'instructions chargées en mémoire pour être exécutées, comme un processus ou une machine virtuelle.
Ressource	Information ou objet logiciel/matériel la contenant, comme un descripteur de fichier ou une clé cryptographique.
Privilège	Autorisation permettant à une tâche de mener une action sur une ressource.
Principe de moindre privilège	Stipule qu'une tâche ne doit bénéficier que des privilèges strictement nécessaires à ses fonctionnalités.
Domaine	Environnement d'exécution d'une tâche défini par l'ensemble des ressources sur lesquelles elle peut agir.
Moniteur de référence	Entité implémentant le contrôle d'accès et décidant d'autoriser ou d'interdire une action.
Composant de confiance	Composant logiciel ou matériel supposé parfait dans l'analyse de sécurité.

Auto-test

1. Quelle entité prend la décision d'autoriser ou d'interdire une action d'une tâche sur une ressource ?
2. Comment appelle-t-on les interfaces externes d'un composant permettant de communiquer avec un environnement contrôlé par l'attaquant ?
3. À quel niveau de privilège doit être implémenté un véritable contrôle d'accès pour isoler un module ?
4. Que doit-on faire pour les composants de confiance concernant leurs spécifications ?
5. Quel principe stipule qu'une tâche ne doit avoir que les privilèges strictement nécessaires ?

Réponses : **1.** Le moniteur de référence · **2.** La surface d'attaque · **3.** Le noyau · **4.** Des spécifications simples · **5.** Le principe de moindre privilège

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.